Phishing & Threat Intelligence

PEMINDAIAN HEADER EMAIL & TRIAGE ARTEFAK

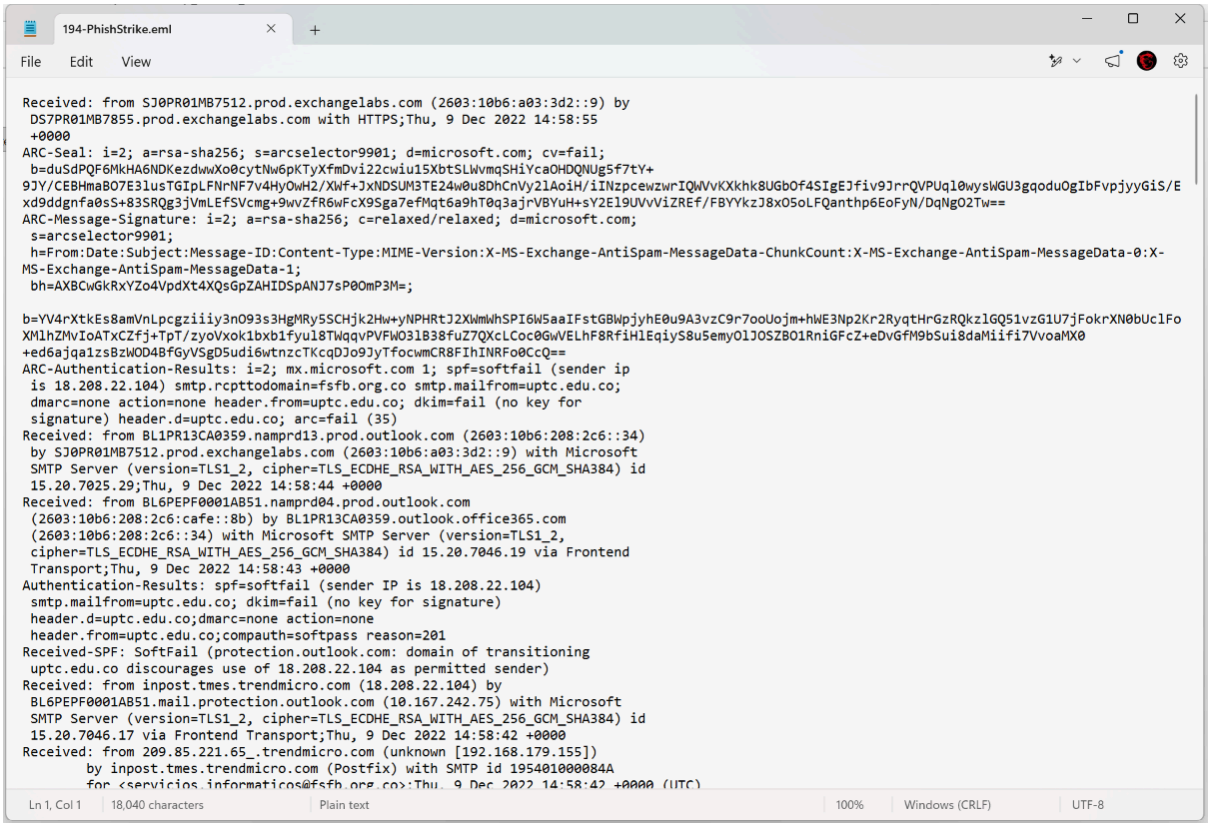
Analyst Name	Analysis Tool	Dataset Log	Analyst Date
Amer Basyarahil	Google Admin	File Artefak .EML & Header	30 Oktober 2026

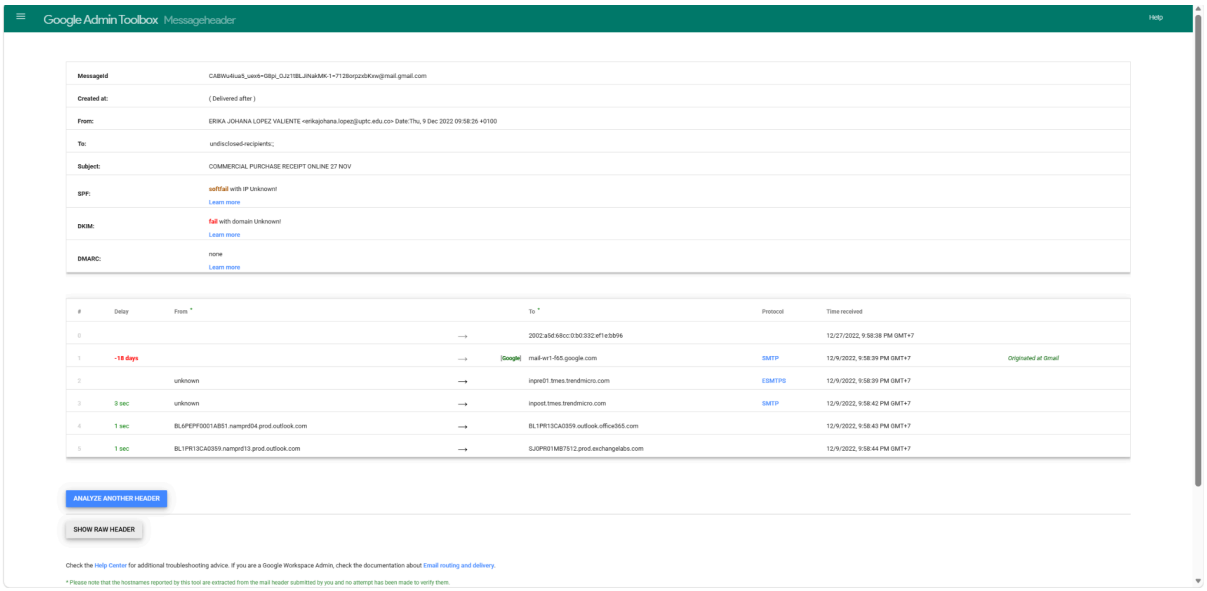
1. Executive Summary

Modul ini mendokumentasikan investigasi insiden analisis email menggunakan pendekatan *Blue Team* standar industri. Analisis berfokus pada validasi otentisitas pengirim melalui verifikasi protokol autentikasi SMTP (SPF, DKIM, DMARC) serta penelusuran jalur pengiriman (*delivery hops*) untuk membedakan ancaman phishing nyata dari pesan yang sah.

2. Kasus A: Analisis Email Phishing Berbahaya (PhishStrike)

Insiden keamanan berisiko tinggi dianalisis dari file artefak mentah 194-PhishStrike.eml. Hasil pemeriksaan header mengungkapkan adanya indikasi pemalsuan identitas pengirim (*address spoofing*) yang mengatasnamakan entitas institusi dengan iming-iming tanda terima transaksi komersial.





Bidang Header	Nilai Mentah Hasil Ekstraksi
Nama & Email Pengirim	ERIKA JOHANA LOPEZ VALIENTE <erikajohana.lopez@uptc.edu.co>
Subjek Email	COMMERCIAL PURCHASE RECEIPT ONLINE 27 NOV
IP Relay Pengirim	18.208.22.104 (Relay Email Tidak Terotorisasi)
Return-Path	smtp.mailfrom=uptc.edu.co
Autentikasi SPF	**SOFTFAIL** (IP 18.208.22.104 tidak terdaftar pada record SPF)
Tanda Tangan DKIM	**FAIL** (Kunci tidak valid / Domain tidak dikenal)
Status DMARC / ARC	**FAIL** (arc=fail (35) / compauth=softfail)

Hasil Keputusan Ancaman: Terverifikasi Spoofing Berbahaya
Hasil pemeriksaan header di Google Admin Toolbox Message Header mengonfirmasi pemalsuan pengirim melalui node relay yang tidak sah. Email ini gagal dalam validasi SPF (softfail) dan DKIM (fail).

3. Kasus A: Triage Artefak & Indikator Ancaman (IOCs)

Metadata email dan alur perpindahan server (*hops*) yang diekstrak dari file 194-PhishStrike.eml dianalisis untuk mengidentifikasi Indikator Serangan (IOCs):

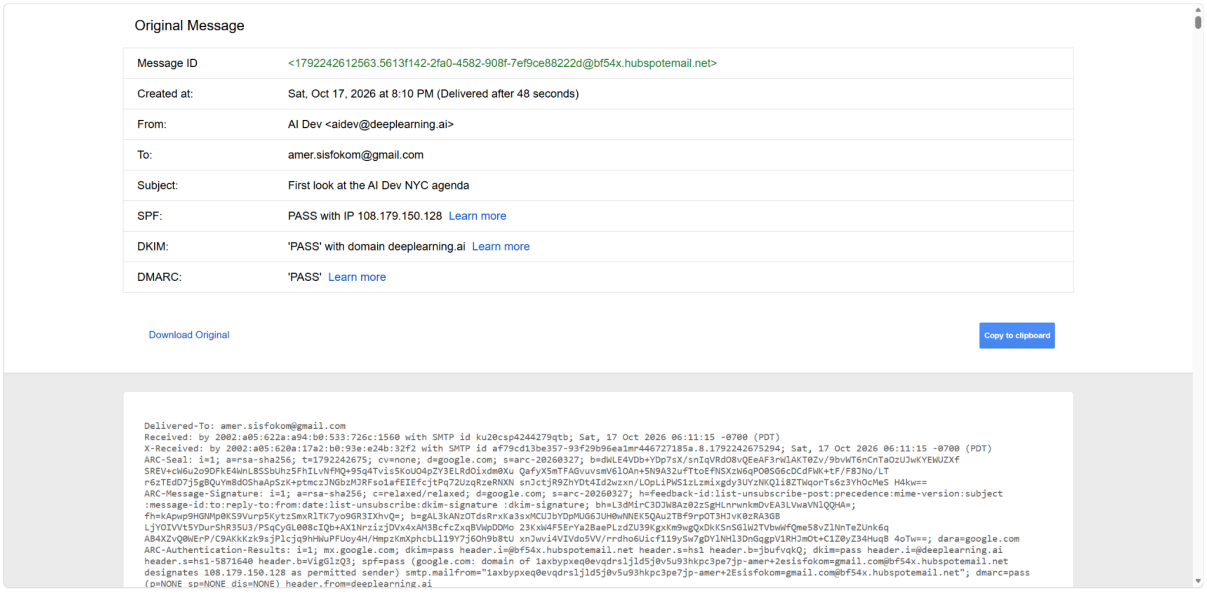
- Message ID: GABWu4Uo5_uex8=08pL_DjZ18LJNwKMK-1=712borpzxb@mail.gmail.com
- IP Relay Pengirim : 18.208.22.104 (protection.outlook.com / trendmicro hop)

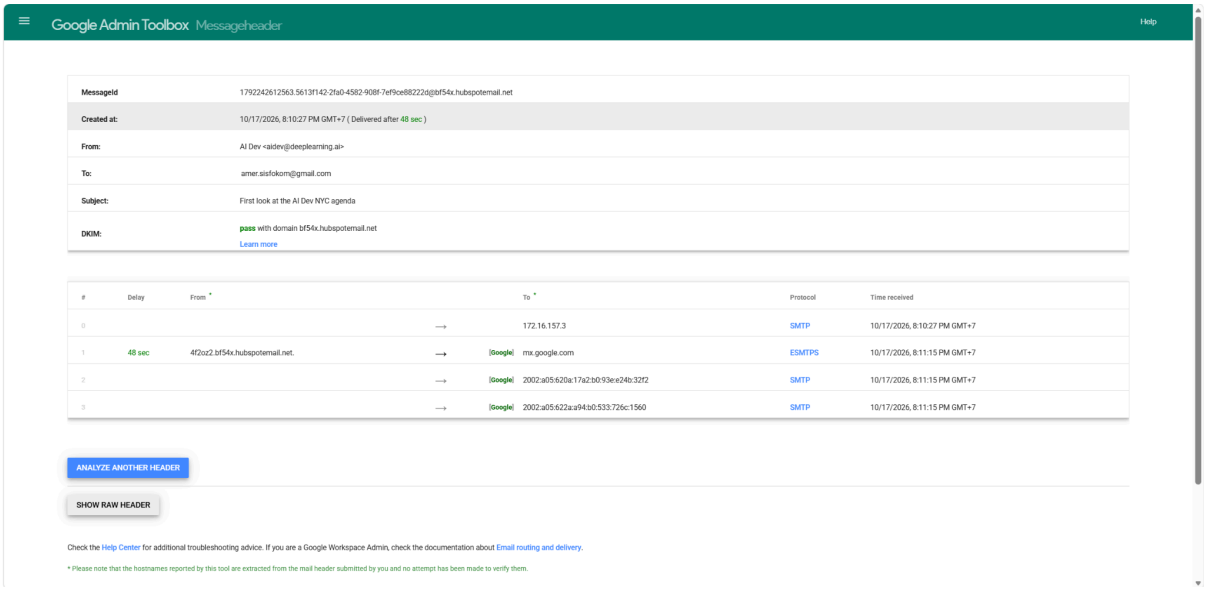
- Hasil Autentikasi : spf=softfail (sender ip is 18.208.22.104) dkim=fail
- Kesesuaian Header : Gagal (Ketidaksesuaian antara mailfrom dan IP relay asal)

Tipe Indikator	Nilai Indikator (IOC)	Tingkat Risiko	Tindakan Penanganan
IP Pengirim	18.208.22.104	**TINGGI**	Pemblokiran di Gateway Email
Identitas Palsu	erikajohana.lopez@uptc.edu.co	**SEDANG**	Penandaan Imersonasi Domain
Relay Hop Email	inpost.tmes.trendmicro.com	**INFO**	Pencatatan Baseline Lalu Lintas SIEM

4. Kasus B: Analisis Email Broadcast Resmi (AI Dev NYC)

Kasus kedua melibatkan investigasi email yang masuk ke folder spam pengguna dengan subjek "First look at the AI Dev NYC agenda". Triage header dilakukan menggunakan Google Admin Toolbox Message header untuk memastikan keamanan pesan.





Bidang Header	Nilai Mentah	Status
Pengirim Asli	AI Dev <aidev@deeplearning.ai>	Sesuai Domain Resmi
IP Pengirim	108.179.150.128 (Server Mail HubSpot)	PASS
Status SPF	PASS dengan IP 108.179.150.128	PASS
Status DKIM	PASS dengan domain deeplearning.ai	PASS
Status DMARC	PASS (Kesesuaian Terverifikasi)	PASS

Hasil Keputusan Triage: Email Resmi (False Positive)
Kasus B berhasil lolos seluruh pengujian kriptografi asal pengirim. Alasan email terfilter ke folder Spam disebabkan oleh sensitivitas filter pemasaran massal (bulk email), bukan karena pemalsuan atau aktivitas berbahaya.

5. Perbandingan Kasus & Ringkasan Analisis Forensik

Perbandingan antara kedua kasus menunjukkan perbedaan utama dalam keabsahan header, kesesuaian domain, dan keandalan infrastruktur pengirim:

Metrik Evaluasi	Kasus A (Email Phishing PhishStrike)	Kasus B (Email AI Dev NYC)
Kesesuaian Header	**TIDAK SESUAI** (Relay IP Tidak Sah)	TERVERIFIKASI (Terotorisasi Hubspot)
Uji Kriptografi	SPF **SOFTFAIL**, DKIM **FAIL**	SPF, DKIM, DMARC **PASSED**
Domain Asal	uptc.edu.co (Domain Target Palsu)	deeplearning.ai (Pengirim Resmi)
Disposisi Insiden	**TRUE POSITIVE** (Serangan Phishing)	FALSE POSITIVE (Pesan Sah)

6. Playbook Penanganan Insiden & Rekomendasi SOC

Untuk melindungi infrastruktur perusahaan dari serangan serupa, tim SOC merekomendasikan langkah-langkah mitigasi dan pengerasan (*hardening*) berikut:

- Memasukkan IP pengirim berbahaya (18.208.22.104) dan indikator domain terkait ke dalam daftar blokir Firewall dan Secure Email Gateway (SEG).
- Melakukan pencarian dan penghapusan (*purge*) pesan yang memiliki pola header serupa dari seluruh kotak masuk pengguna menggunakan konsol Admin Google Workspace / M365.
- Mengkonfigurasi *record* DMARC organisasi ke mode p=reject untuk menolak secara otomatis email yang gagal validasi SPF dan DKIM.
- Meningkatkan pelatihan karyawan dalam mengidentifikasi tanda-tanda email penipuan dan memeriksa keabsahan alamat pengirim sebelum merespons.

Rangkuman Operasional Analis SOC

Modul ini membuktikan kemampuan praktis dalam membedakan komunikasi masal yang aman dari kampanye phishing berbahaya melalui dekoding header, verifikasi otentikasi, serta triage ancaman secara presisi.